来源标注不完美时，Agent 数据流策略的安全—可用性边界

Security–Utility Tradeoffs under Imperfect Source Annotations in Provenance-Aware LLM Agents
研究议程修订稿 R1 · 2026-10-11 · **DRAFT，未注册/未定稿；新实验 PLANNED/UNRUN**

1. 研究问题、冻结证据与文献定位

问题：来源标注不完整、过时或错误时，Agent 数据流策略的安全性与可用性如何变化？ 区分标签传播正确、授权真实、分类语义正确。候选贡献收窄为：在统一任务和可验证执行证据下，随机、结构漂移及适应性地干预 LLM-Agent IFC 的来源标注，估计暴露条件化的安全—可用性曲线。不声称首次研究错误标签、Schema 感知或声明可信性。

PR #5 冻结于 `5c2b86c`，255 个文件逐一哈希；V1.10 原有 212 文件是另一口径。以下为历史唯一任务结果，14 攻击、12 正常，2 控制不入分母；三次重复不是新任务：

策略	ASR ↓	TCR ↑	FPR ↓
粗粒度	8/14	3/12	9/12
当前精细化	11/14	8/12	4/12
保守精细化	4/14	7/12	5/12

局部结果说明保守默认的权衡，不能证明泛化或最优性。合法错误 PUBLIC 仍泄露。历史 36 项模型 UNRUN 不构成模型防御证据；本轮没有新安全实验。

原文定位（详见 `LITERATURE_MATRIX.md`）： CaMeL [1] 已有细粒度来源/读者与执行前策略；FIDES [2] 已有结构化节点标签、隐藏及受约束揭示。APPA **v2** [3]（2026-08-26）已有未标注工具的 Unknown/cast；合同准确与 cast 正确是条件，Schema 只约束形状，不保证语义。AgentFlow [6] 已注入 12 类不安全策略变体；Prudentia [7] 已定义 HITL load 与 TCR@k。结构化 MCP 标签及标注负担 [8]、移动应用 flow-to-label/flow-to-policy 一致性 [9–10] 均已有研究。FlowSeal [4] 的语义降密另依赖判断器。

上述能力都不作为本项目创新。尚需逐项对齐工件与干预粒度，不能从选读文献推断近邻未做某项实验。拟加入 **FIDES 与 APPA v2** 两个外部机制基线，AgentFlow 为替代候选；尚未适配或复现。适配不可行须记录接口差异，论文定位退回 AgentShield 内部测量研究。初步综述不证明新颖性。

2. 威胁模型、因果分层与不可识别性

保护对象是独立契约规定的敏感数据，保护方向是到**未授权主体/sink**的显式传播。真值仅供注入器和评估器使用，不进入可部署防御；oracle 上界单列。

情形	单独干预的对象	可检验边界
诚实但错误的发布者	有效授权下的漏标、反向错标	认证不提供语义保证
合法凭据被滥用的发布者	在授权范围内定向 PUBLIC	内部人威胁；独立证据/权限隔离
正确发布者，消费链过时/分歧	旧目录、缓存、版本或解析规则	版本一致性检查；目录也可过时
未授权声明攻击	工具文本自称 PUBLIC、伪造/撤销后重放	真实性与撤销检查

四类分别报告，不能把发布错误、内部人和缓存故障混合后归因给同一机制。定向腐化实验明确赋予标注写权限；普通提示注入者没有这种权限，不能混称同一攻击。

TCB 包含受控运行时、中间件、授权/目录验证器、独立评估器与本机接收端。发布者可能错标，授权真实性与分类正确性分开。模型、工具文本不得制造放行权限；实现错误、解析器分歧作为单独故障面。输出前校验和发送须绑定同一内容与作用域。

模型上下文不是一概禁止的 sink：契约分别标识主模型、第三方提供方、隔离子模型、用户及 HTTP 接收主体，指定读者、用途与任务必需读取。合法阅读与非法外传分别计分；本轮主实验只拟用本机 HTTP，不推断真实模型效果。

限定边界：受控 AgentPort、包装值与已支持显式转换；不涵盖任意 Python、第三方内部变换、模型改写/摘要、隐式及时间通道。精确载荷送达只能证明显式泄露。二值 PUBLIC/SENSITIVE、平衡合成字段和本机 HTTP 不代表真实标签基率、读者集合或用途。

不可识别性：两种语义真值若给防御相同值、类型、来源、版本与合法 PUBLIC 声明，只有这些输入的判定无法区分它们。签名、哈希和结构检查不足以恢复语义；这是限定输入论证，不是系统非干扰证明。

候选机制仅为版本/结构校验：新增/缺失字段、类型变化、未知版本记不确定，PUBLIC 父容器不自动授权新增子字段；授权、冲突、有限审查另列轴。先完成开发期 E0–E3 测量，再选择最小机制，不预设语义分类器或完整授权系统。

3. 配对干预、暴露与正确预算

拟议材料，尚未收到/生成：120 来源家族，60 开发、60 外部作者保留；每家族攻击/正常各一任务，共 240。每家族至少 20 叶字段，首面板真值平衡；1%、10%、90% 敏感基率及相关错误另作探索性面板。分层文件/工具、嵌套/列表与支持的显式转换，使用扫描器不命中的虚构载荷。共享模板上提为统计簇，开发与保留不得共享模板。

实验	干预	配对规则
E0	正确标注，零错误一次	固定任务与真实接收证据
E1	敏感→公开、公开→敏感、双向随机叶错标	同家族攻击/正常共用同一腐化图及摘要
E2	遗漏/新增、旧版、类型/解析/目录冲突	每变体与正确 Schema 对照共享当前数据和契约
E3	定向改输出依赖字段	与 E1 相同受影响家族及逐家族叶预算

E1 比例 **0、5%、10%、25%、50%、100%**，非零注入种子 **17、29、43、71、101**。跨家族池按固定随机排名取前缀，分别导出两方向实际错误叶数/真值叶总数。三策略看到完全相同的图；攻击/正常不得重新抽样。E3 叶级主配对复用逐家族预算；父容器/整源按所有实际改变的叶计费，不可比的预算单列。模板、前缀、整源、目录级相关故障分开扩展。

在执行前固定攻击依赖叶集合 D 与错误集合 K，定义 **X_any=敏感依赖叶至少一项被错标 PUBLIC**，另报 X_all 与命中比例。无条件 ASR、ASR｜X_any、每家族暴露率同时报告；零暴露的条件率为 null。暴露按干预与契约算，不能按实际允许/送达定义。跨比例条件率可能换人群，不解释为纯因果剂量效应。E3 配对比较完整的同受影响家族，不按两攻击的泄露结果挑选。

预算更正：E0 一次，非零为 5 比例×3 方向×5 种子，共 **76 注入条件**。240×76×3=**54,720 条**；开发与保留各 27,360。先前 57,600 错把 E0 乘了五个注入种子。新预算不含 E2/E3、外部基线、控制或模型重复，不是独立样本数，更不是执行许可。

先拟做 12 个开发家族 pilot：24×(1+2 比例×3 方向×2 种子)×3=936，另 48 个传输/全拒控制，共 984。只估失败率、暴露、耗时、方差/ICC 不确定性和可检测效应，不宣布安全提升。算法、阈值及功效方案须在保留结果前锁定；不足则停止确认性推断。E3 开发最多每任务 20 查询；保留只用冻结攻击，不据其结果改实现。

4. 假设、效用约束与独立验证

以下是可证伪的提议，尚未注册。效应以绝对比例差表示，详见 `PROTOCOL_DRAFT.md` 和 `protocol-draft.json`。H1–H3 为次要预设检验，H5 为共同主判据；H4 仅在机制冻结且获得未看过的材料后启用。

假设	对照与估计量	拟议判定界
H1	当前策略，敏感→公开 p=.25 vs E0，ΔASR	下界 > +.05
H2	当前策略，公开→敏感 p=.25 vs E0，ΔTCR/ΔFPR	上界 < −.05 且下界 > +.05
H3	当前策略，p=.10 定向 vs 匹配随机，ΔASR	下界 > +.05
H4	纯结构候选 vs 当前：结构故障改善、合法语义错标等效	改善 > .05；后者区间全在 ±.02
H5	保守 vs 当前，敏感→公开 ASR AUC 与逐点 TCR	安全、相对与绝对可用性**全部**满足

H5 拟要求 ΔASR AUC 上界 < −.05；六个比例点 ΔTCR 的同时下界均 > −.05，且保守 TCR 同时下界均 ⩾ .80。**全拒绝因此不能成功，即使对照也很差**。5 个百分点效应/非劣界、80% 最低完成率和 2 点等效界是待评审的任务要求，不来自历史效果或 pilot 选优；缺少可接受依据/功效时不启用确认性检验。H4 不用“不显著”证明等效。

主区间只基于**外部保留集**；开发集只校准运行性、方差、ICC、预算，合并分析仅次要且加入 split 交互。按模板（无共享模板时家族）配对簇 bootstrap 10,000 次，保留所有任务/种子/变体/策略；同时区间覆盖全部预设不等式。小簇数、退化重采样或功效不足仅报告探索性。六点梯形面积是网格摘要，不是部署期望；暴露条件面积不替换主终点。

ASR 以独立接收敏感载荷为分子，TCR 要求执行、接收/任务状态与回执，FPR 是正常任务中间件误阻断。每格记录 eligible/observed/excluded、家族/模板数及分子分母；UNRUN 不计 HELD，给缺失上下界。成功判据须在最坏缺失归属下仍满足且各格覆盖 ⩾95%，否则不确认。外部环境阻断不能归功于防御。

人工审查沿用 Prudentia 的 HITL load/TCR@k，另报失败任务请求、时延/超时/错审；零预算、有限审查与真值 oracle 分开。额外耗时只用同任务 No Defense 配对，否则 null。真实模型、AgentDojo、外部攻击和第三方复跑仍未执行；需独立协议与可用凭据，不让这些线替代主问题。

推进门禁：文献矩阵/协议评审 → 开发 pilot 与冻结清单 → 开发 E0–E3/选最小机制 → 冻结实现、生成器和攻击 → 外部保留单次分析 → 第三方与真实 Agent。看过保留结果后修改任何实现、生成器或攻击，该集降为开发集，须换新保留集。可以交付内部测量与边界分析，不承诺新机制或新颖性。

原文链接与精确范围见文献矩阵；本轮未复现任何外部防御：
[1] CaMeL v2；[2] FIDES v1；[3] APPA v2；[4] FlowSeal v1；[5] AgentDojo v1。
[6] AgentFlow v1；[7] Prudentia v1；[8] Towards Verifiably Safe Tool Use；[9] Lalaine；[10] PoliCheck。